



Risk Register

TASCO Insurance × VETC Growth Platform — Delivery & Change

iorta TechNXT

Version 1.0 · 07 October 2026

Scoring: Likelihood (L) 1–5 × Impact (I) 1–5 = Score (S). **Rating:** 1–6 Low · 8–12 Medium · 15–25 High. **Status values:** Open · Mitigating · Monitoring · Closed.

The register is reviewed weekly by the Delivery Lead and PO, and the top 10 go to every Steering Committee. Owners are named roles; see [raci.md](#) for the party codes.

Heat map (current scores)

L \ I	1	2	3	4	5
5					
4			R-14	R-04, R-06, R-12	R-01
3			R-17, R-21, R-24, R-27	R-07, R-08, R-09, R-11, R-13, R-15, R-16, R-19, R-20, R-25, R-28	R-02, R-03, R-05, R-10
2		R-26	R-18, R-23, R-30	R-22, R-29	
1					

Register

ID	Risk description (cause → event → effect)	Category	L	I	S	Owner	Mitigation (pre-event)	Contingency (if it happens)	Status
R-01	VETC data access delayed or restricted. The data-sharing legal basis or VETC internal approval is not obtained in time, so no real profile data reaches the platform and scoring and journeys cannot be validated on real behaviour.	Dependency / Data	4	5	20	V-PRD + T-BUS	Data-sharing agreement drafted in week 1. Minimum viable field list agreed (plate, phone, toll class, tag date, app activity, consent flags). Synthetic generator keeps the build moving.	Start the pilot on TASCO's own policy book (renewal journey only) with VETC contact through the app only. Escalate to SteerCo.	Open
R-02	Discount/benefit regulation. Customer-facing copy or a benefit is construed as an unlawful discount, rebate or inducement on price-regulated TNDS (Law 08/2022/QH15), leading to regulatory sanction and reputational damage.	Regulatory	3	5	15	T-CMP	Copy guard (<code>copy_guard.json</code>) at rule validation and at send time. Benefits gated by <code>legalStatus</code> (only approved shown to customers). Pricing copy states "regulated premium, same everywhere". Legal sign-off of every template and the voice script at G3.	Deactivate the offending template or benefit through the Rules studio (new version, approved within the hour). Customer notice if required.	Mitigating

ID	Risk description (cause → event → effect)	Category	L	I	S	Owner	Mitigation (pre-event)	Contingency (if it happens)	Status
R-03	Loyalty points promised before legal approval. NBA label "confirm expiry in-app (earns points)" and data-repair messaging imply points while <code>loyalty_points</code> is <code>pending_legal_review</code> , creating a mis-selling or inducement complaint.	Regulatory / Content	3	5	15	T-CMP	Remove the "earns points" wording from the NBA label and customer app until approved. UI shows points only when the benefit is approved.	Withdraw the wording. Honour any points already promised through a non-cash goodwill gesture approved by Legal.	Open
R-04	Anti-spam breach. Journey frequency, contact windows or missing consent breach Decree 91/2020/ND-CP, leading to carrier blocking of the brandname, fines and complaints.	Regulatory	4	4	16	T-CMP	<code>contact_policy</code> enforces 08:00–20:00 local time, 1 marketing contact per day, 3 per week, 2 call attempts per week, and consent per channel. Service messages are exempt only where truly service. Weekly review of message volumes per customer. Fix known issue KI-09 (voice campaigns bypass the contact window and call caps) before pilot.	Pause journeys (stop the scheduled <code>journeys</code> job). Tighten the policy through the Rules studio. Notify carriers and the regulator if required.	Mitigating
R-05	PDP law non-compliance (Decree 13/2023/ND-CP; the PDP Law effective 2026). Personal data is processed without valid consent or purpose, or a DSAR is not honoured in time, leading to fines and suspension of processing.	Regulatory / Privacy	3	5	15	T-CMP (DPO)	DPIA in Discovery. Consent centre in the customer app. DSAR export and erasure endpoints. PII field encryption and blind indexes. Purpose-based masking. Retention rule set. Data localisation confirmed.	DPO incident procedure. Notify the authority within the legal deadline. Suspend the affected processing.	Mitigating
R-06	Partner channel conflict. Partners (banks, showrooms, agents) that close most TNDS deals see VETC journeys as poaching their customers, so they withdraw or reduce volume.	Commercial	4	4	16	T-PRD (Partner Manager)	Partner API with transparent commission. Partner-attributed vehicles are recognised through partner source records. Agreed rules of engagement (for example, suppress conquest for vehicles recently quoted by a partner). Partner council.	Commercial renegotiation. A NBA rule that suppresses VETC journeys for partner-protected vehicles.	Open

ID	Risk description (cause → event → effect)	Category	L	I	S	Owner	Mitigation (pre-event)	Contingency (if it happens)	Status
R-07	Low customer trust in calls. Customers assume voice bot or telesales calls are scams, causing low answer and conversion rates, complaints and opt-outs.	Customer / Brand	3	4	12	V-PRD	Disclosure at call start. Plate-first verification (the bot never reads the plate). "Never asks for OTP or payment". Payment only in the official app. Calls from the official hotline. In-app notice before or after the call. Trust script on scam concern.	Shift the mix to app/Zalo, reduce call volume, run a public awareness campaign in the VETC app.	Mitigating
R-08	Voice ASR accuracy for Vietnamese accents. The ASR misrecognises plates and intents for northern, central and southern accents, noisy cars or code-switching, causing high unverified / plate_mismatch outcomes and customer frustration.	Technology	3	4	12	X-VAI + I-AR	Vendor shortlist with accent benchmarks ($\geq 92\%$ plate-capture accuracy proposed). Up to 3 plate attempts. Keyword NLU covers unaccented variants. Monitor <code>plateVerificationFailureRate</code> on the governance dashboard.	Route failed verifications to telesales or a link. Retune the vendor. Swap the vendor behind the telephony port.	Open
R-09	Integration delays (VETC wallet, SSO, TASCO core issuance). APIs are not ready for SIT, so one-tap purchase cannot be tested end-to-end and the pilot slips.	Dependency	3	4	12	T-IT + V-APP	Contracts frozen at G1. Sandbox adapters with identical ports. Contract tests. Twice-weekly integration sync.	Pilot with signed links plus telesales issuance. Shift the pilot start and hold the Tết freeze.	Open
R-10	Adoption by telesales. Agents keep working from spreadsheets or call lists and ignore the inbox and NBA, so handoffs go stale and conversions are lost.	Change / People	3	5	15	V-CC + T-PRD	Involve agents in usability tests. Champions network. Inbox designed for ≤ 3 clicks to claim and call. Incentives aligned with platform-recorded wins. Supervisor dashboards.	Supervisor reassignment, targeted coaching, retire the legacy lists.	Open
R-11	Model / scoring bias. Scoring factors (engagement, wallet balance, region) systematically deprioritise certain groups (for example rural or low-balance customers), leading to unfair treatment and regulatory or ethical concern.	AI governance	3	4	12	T-DAT + T-CMP	Explainable additive scoring with reasons per factor. No protected attributes used. Quarterly fairness review by province and vehicle category. Simulation before changes.	Adjust weights through the Rules studio. Add a minimum-service rule so every lapsed vehicle gets at least a service notice.	Monitoring

ID	Risk description (cause → event → effect)	Category	L	I	S	Owner	Mitigation (pre-event)	Contingency (if it happens)	Status
R-12	Key person dependency. Knowledge of the rules engine and enrichment logic sits with one or two iorta engineers, so the platform cannot be maintained if they leave.	People / Delivery	4	4	16	I-DL	Pairing. ADRs. KT plan with reverse-shadow. Code walkthroughs. Documentation as part of the DoD. Two people trained per component.	Accelerate KT. Retain an iorta support contract.	Mitigating
R-13	Vendor lock-in (voice-AI, messaging, cloud). Proprietary APIs make switching costly or impossible.	Architecture / Commercial	3	4	12	I-AR	Hexagonal ports and adapters (<code>src/adapters/integrations/*</code> , composition root <code>src/bootstrap/container.js</code>). Standard PostgreSQL. No proprietary cloud services in the core. Exit clauses in contracts.	Replace the adapter. Data export from vendor contracts.	Monitoring
R-14	Data quality worse than assumed. Expiry is reliable for fewer records than expected (baseline ≈ 1 in 10), so journeys mistime and customers are contacted about the wrong date.	Data	4	3	12	T-DAT	Confidence-based NBA (<code>fix_data</code> asks for confirmation when confidence < 0.5). <code>verify_expiry</code> steps. Voice bot captures expiry. Data steward workflow. DQ KPIs.	Restrict the pilot to records with confidence ≥ 0.5. Run "confirm your expiry" campaigns first.	Mitigating
R-15	Wrong-person contact and privacy leak. A phone number in VETC data belongs to someone else (sold car, shared phone), so PII or policy data is disclosed to the wrong person.	Privacy	3	4	12	T-CMP	Plate-first verification before any detail. Masked plate in calls. Minimal data in messages. <code>wrong_person</code> outcome creates a DQ issue.	Incident handling, DQ correction, apology.	Mitigating
R-16	Payment without explicit customer authorisation. Telesales or partner flows trigger a VETC wallet debit (<code>POST /api/orders</code>) without the customer confirming in their app, leading to disputes and a breach of the "never pay by phone" promise.	Process / Integration	3	4	12	V-APP + T-PRD	In production the wallet adapter must require customer confirmation in the VETC app (push-to-approve). Agents send one-tap links rather than issuing. Issuance permission (<code>policy:issue</code>) is restricted and audited.	Refund through compensation. Reconcile. Retrain agents.	Open

ID	Risk description (cause → event → effect)	Category	L	I	S	Owner	Mitigation (pre-event)	Contingency (if it happens)	Status
R-17	Zalo ZNS template approval or OA verification delayed. Templates are rejected or slow to approve, so the Zalo channel is unavailable at pilot.	Dependency	3	3	9	V-PRD	Submit templates in Sprint 2. Templates written within ZNS rules (transactional tone). Channel fallback order in journeys.	Use app push and SMS only.	Open
R-18	Physical damage sold without the required inspection. MOTOR_PD has requiresInspection: true, but the quote → order flow (including the v1 customer app add-on toggle) binds without inspection, leading to underwriting losses and fraud.	Underwriting	2	3	6	T-PRD (Underwriting)	MVP offers physical damage as quote / lead only in the app. Binding goes through the inspection workflow (self-inspection photos or a centre).	Hold MOTOR_PD issuance on digital channels by removing vetc_app from its channels (rule change).	Open
R-19	Rule misconfiguration (scoring, journeys, tariffs). A wrong rule is approved, leading to mis-priced quotes or mass mis-targeting.	Operational	3	4	12	T-CMP	Validation, simulation and four-eyes approval. Description required. Monitoring after activation. Tariffs approved by Underwriting.	Rollback (new draft from the prior version, fast-tracked approval). Customer remediation.	Mitigating
R-20	Security breach / account takeover of staff or partner credentials, leading to data exfiltration or fraudulent issuance.	Security	3	4	12	T-SEC	MFA for admin, approver, compliance and steward roles (extend to all roles in production through the IdP). Lockout after 5 failures. Short JWT TTL (30 min). Rate limits. API keys hashed and shown once. Audit hash chain. Pen test.	Revoke tokens and keys, disable users (PATCH /api/users/:id), incident response, forensics from the audit log.	Mitigating
R-21	Telecom/notification provider outage , so reminders and calls fail around expiry dates.	Operational	3	3	9	T-IT	Circuit breakers per gateway. Ops status page. Journeys retry the next channel. Catch-up window (catchUpDays).	Manual re-run of journeys for missed dates. Switch provider.	Monitoring
R-22	Performance at full base (≈ 6M vehicles). Recompute or ingestion jobs exceed batch windows, so leads go stale.	Technology	2	4	8	I-AR	Incremental rebuild by plate. Paging (1,000 per page). Postgres indexes. Perf tests. Horizontal scaling.	Run jobs off-peak. Partition by province.	Monitoring
R-23	Scope creep (new products and journeys added mid-build), pushing the MVP late.	Delivery	2	3	6	T-PRD	Rules-first design: many requests are configuration, not code. Change control at SteerCo.	Move to Wave 3.	Monitoring

ID	Risk description (cause → event → effect)	Category	L	I	S	Owner	Mitigation (pre-event)	Contingency (if it happens)	Status
R-24	Tết and holiday disruption. Release or pilot activity coincides with Tết, when customers and staff are unavailable.	Schedule	3	3	9	I-DL	Change freeze 1–14 Feb 2027. Soft launch before, full volume after.	Re-plan the pilot.	Mitigating
R-25	Customer-app experience below expectation (VETC webview limits, slow load), so renewals fall back to telesales.	UX	3	4	12	I-UX + V-APP	Performance budgets, usability tests, ≤ 3 taps, skeleton loading, offline-tolerant retry with idempotent orders.	Fix-forward weekly releases. Zalo mini-app fallback.	Open
R-26	Accessibility non-conformance , leading to complaints and exclusion of older drivers.	UX / Compliance	2	2	4	I-UX	WCAG 2.2 AA in the DoD, automated and manual checks.	Remediation sprint.	Monitoring
R-27	Claims expectations not met. FNOL fast-lane promises a 4-hour acknowledgement but the claims team is understaffed, damaging trust at the most important moment.	Operational	3	3	9	T-PRD (Claims Lead)	SLA visible in the claims queue (<code>slaDueAt</code>). Staffing plan. Alerts.	Overflow to the TASCO claims hotline. Adjust the published SLA.	Open
R-28	Commission miscalculation or caps exceeded , leading to regulatory breach or partner disputes.	Financial / Regulatory	3	4	12	T-PRD (Finance)	Statutory caps in <code>commission.json</code> enforced by the validator and again at calculation (<code>Math.min(rate, cap)</code>). Monthly statements. Reconciliation.	Adjust and re-issue statements. Claw back.	Mitigating
R-29	Audit or log integrity failure. Audit records are tampered with or lost, so compliance evidence is unavailable.	Compliance	2	4	8	T-SEC	Append-only hash chain with <code>GET /api/audit/verify</code> . Retention of 10 years. Backups.	Restore from backup. Forensic investigation.	Monitoring
R-30	Rule cache lag across replicas. An approved rule takes up to 15 s to propagate (<code>CACHE_TTL_MS</code>), giving inconsistent behaviour briefly.	Technology	2	3	6	I-AR	Event <code>rules.activated</code> invalidates the cache. The short TTL is documented.	None needed beyond awareness. Avoid approving during a peak-send window.	Closed (accepted)

Risk review procedure

1. New risks can be raised by anyone through the delivery tracker using the template above.
2. The Delivery Lead triages within 2 business days, assigning an owner and an initial score.

3. Any risk scoring **High (≥ 15)** is escalated to the next Steering Committee with a mitigation plan.
4. A risk is closed only when its owner and the Delivery Lead agree that the cause no longer exists or the residual risk has been accepted by the accountable party in the RACI.